Лабораториска вежба 5 – Тројанци	Име и презиме Dario Jakovleski	Индекс 222015

Текстуалните одговори давајте ги со црвена боја.

1. Дел 1

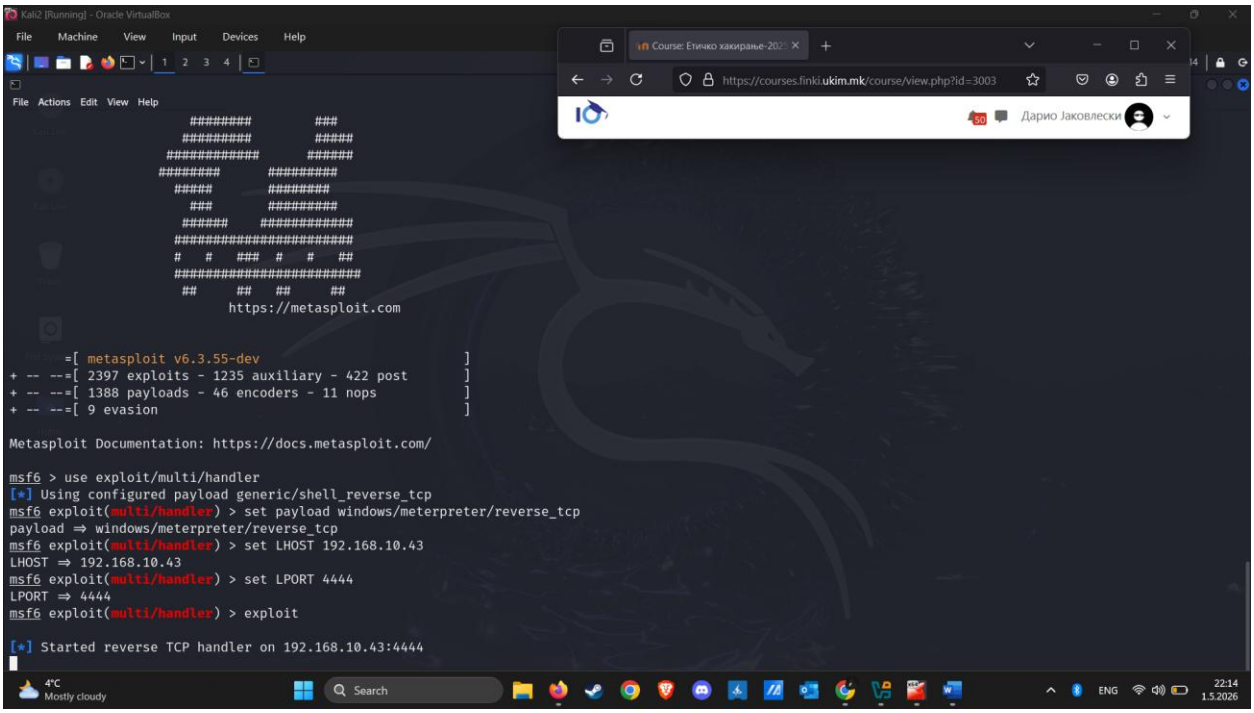
Прашање 1: За кој payload се одлучивте? Зошто?

Одговор 1:

Го избрав windows/meterpreter/reverse_tcp бидејќи нуди целосно опремена вградена во меморијата (Meterpreter) наместо основна CMD shell. Варијантата reverse_tcp значи дека машината-жртва ја иницира конекцијата назад кон Kali, што ги заобиколува повеќето правила за влезен заштитен ѕид. Компатибилен е со x86, што одговара на користениот 32-битен шаблон putty.exe.

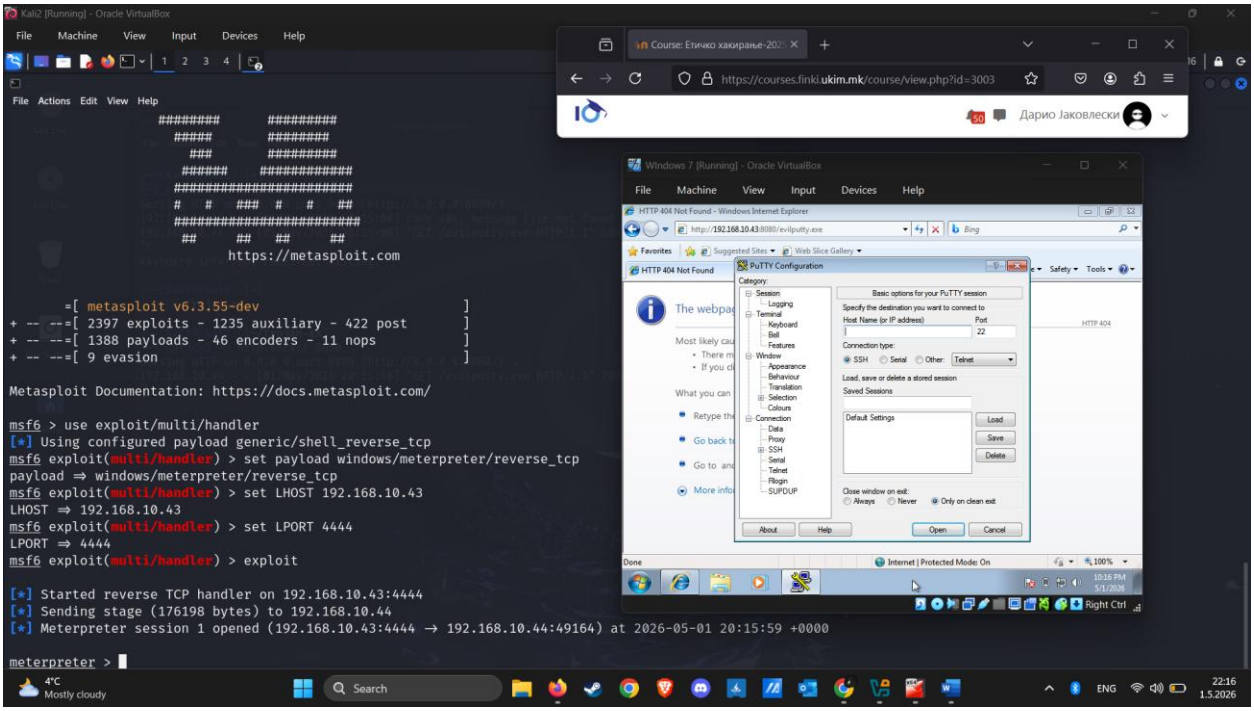
Прашање 2: Поставете слика од извршувањето на `exploit/multi/handler` модулот

Одговор 2:



Прашање 3: Дали беше успешно воспоставена сесија со Metasploit користејќи го избраниот payload? Ако да, поставете слика од извршувањето на некоја CMD команда (`ipconfig`, `systeminfo` или некоја друга по желба). Ако не било успешно воспоставувањето на сесијата, пробајте да откриете што е проблемот и дадете свое мислење. Повторете ги горните чекори со користење на друг payload.

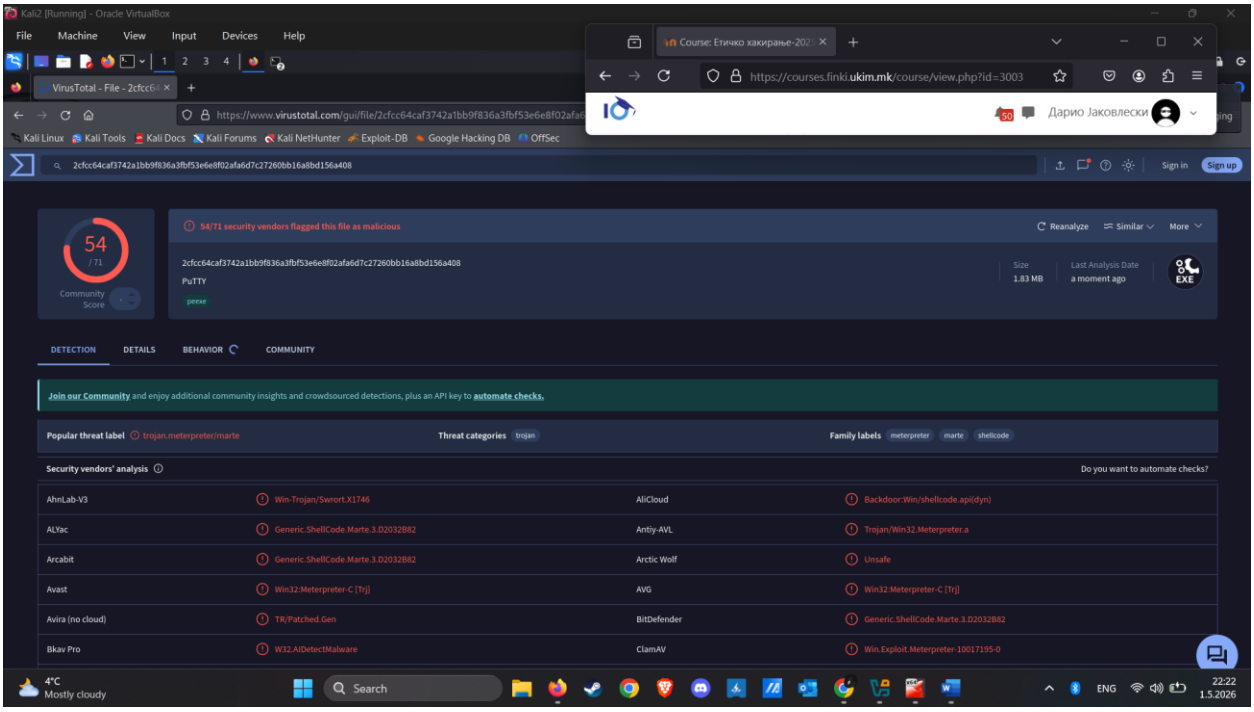
Одговор 3:



Успрешно беше воспоставена сесија.

Прашање 4: Дали некој од поддржаните анти-вируси го детектира тројанецот? Поставете слика од резултатите.

Одговор 4:



Да многу анти-вирусни го детектираа тројанецот.

Прашање 5: Кои encoder-и ги одбравте? Зошто? Како работат?

Одговор 5:

Ги избрав x86/shikata_ga_nai и x86/countdown.

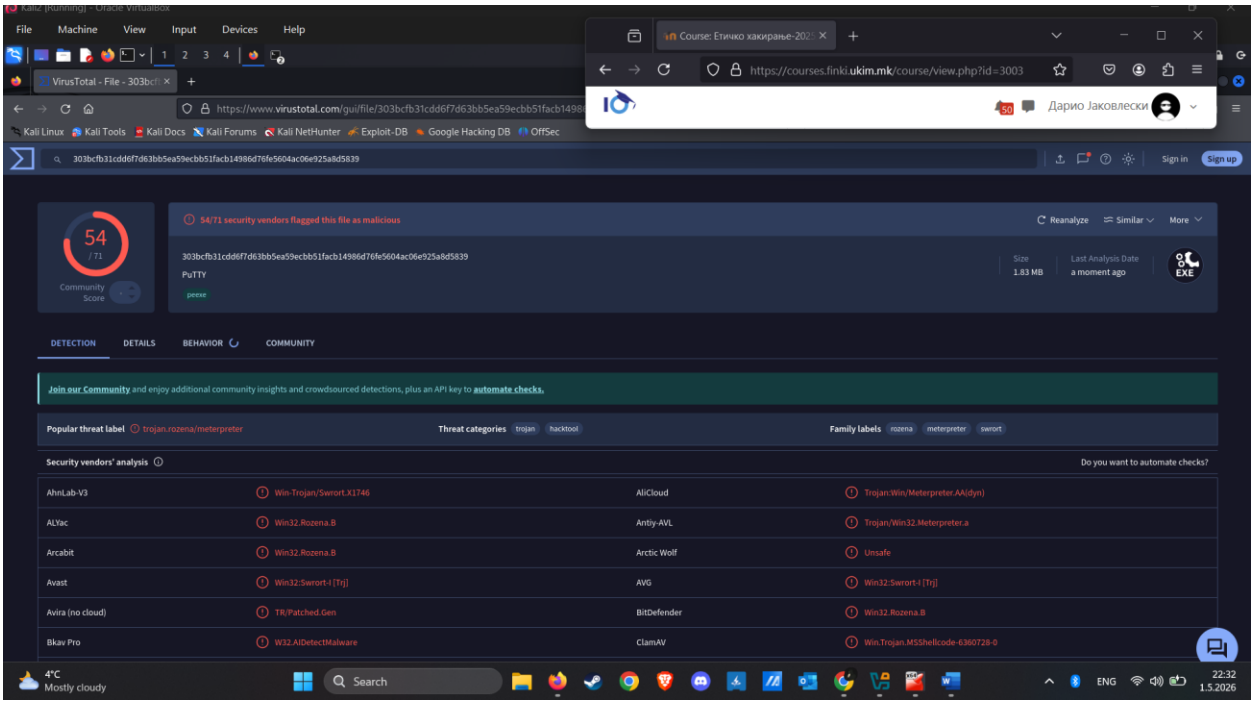
Shikata_ga_nai е полиморфен XOR кодер за адитивна повратна информација оценет како „одличен“ од Metasploit. Секоја итерација на кодирање произведува бајткод со различен изглед кој се самодекодира за време на извршување користејќи stub претходно поставен на payload-от. Бидејќи излезот се менува со секое извршување, потешко е за статичкиот AV базиран на потпис да се совпадне со него.

x86/countdown е поедноставен XOR кодер со еден бајт. Тој одзема од бројач за да го декодира payload-от за време на извршување. Беше избран како контраст на shikata_ga_nai за да се набљудува дали комплексноста на кодерот влијае на стапките на откривање.

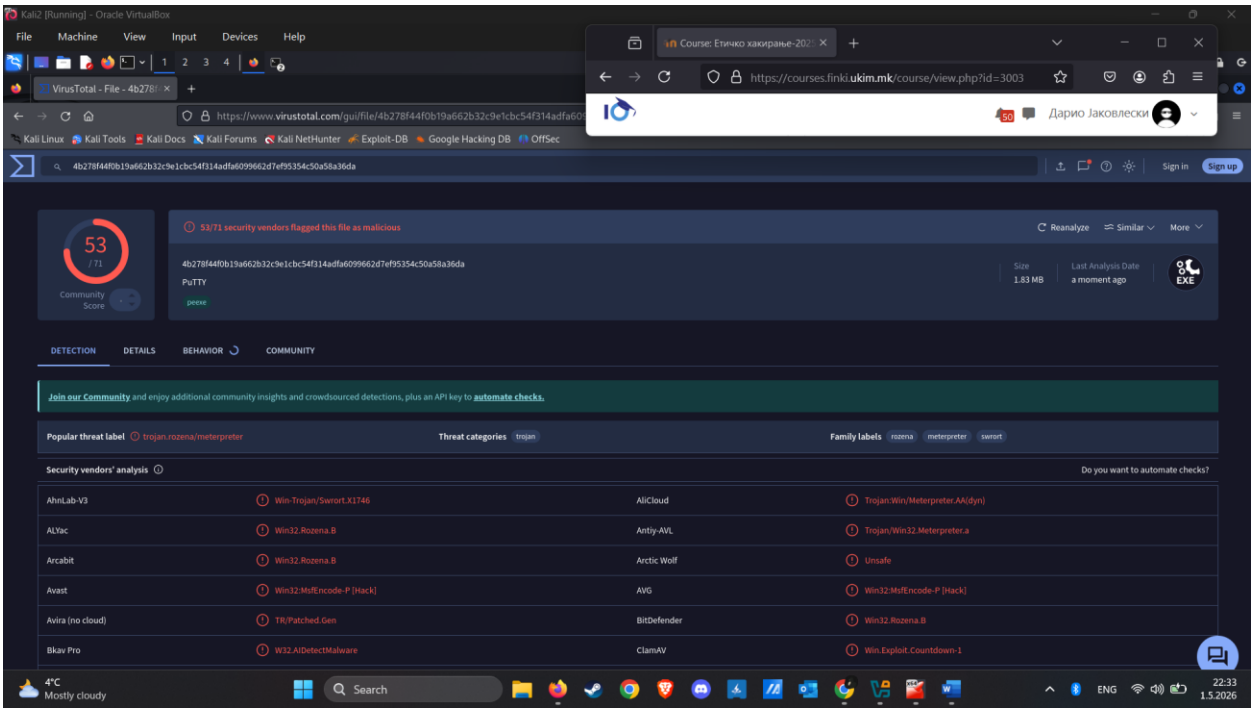
Прашање 6: Колку успешни детекции има на секоја од енкодираните датотеки? Дали енкодирањето ја намали ратата на детекција? Поставете слика од VirusTotal резултатите за секоја од верзиите.

Одговор 6:

Shikata_ga_na ekodirano



X86/countdown enkodirano

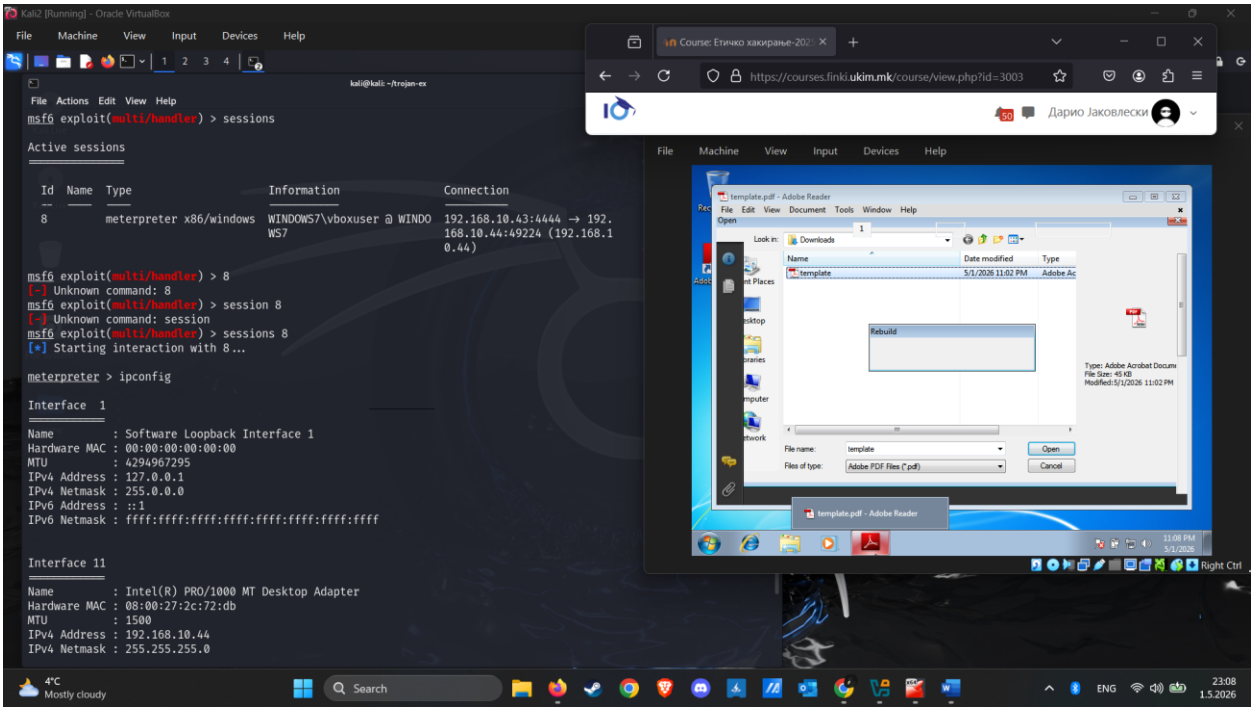


Ратата на декеција не беше намалена, што значи дека денешните системи се паметни за да го откриај ова енкодирање и ние е доволно за прекривање.

2. Дел 2

Прашање 7: Дали експлоатацијата со малициозната PDF датотека беше успешна? Поставете слика од отворената PDF датотека на Microsoft Windows виртуелната машина, како и од воспоставената конзола во Metasploit.

Одговор 7:



Da konekcijata e uspesna, pdf datotekata nemoze celosno da se otvori (sporo e) bidejki windows mashinata ima malku resursi no sepak toe ne e precka da se vospostavi konekcijaa.

Прашање 8: Дадете ваше размислување како може да се заштитиме од вакви напади со малициозни датотеки. Образложете.

Одговор 8:

Заштитата од вакви напади бара повеќеслоен пристап, бидејќи ниту една единствена мерка не е доволна сама по себе.

1. Редовно ажурирање на софтверот

Ранливоста CVE-2010-2883 која беше искористена во оваа вежба беше закрпена уште во Adobe Reader 9.4. Ова јасно покажува дека редовното ажурирање на софтверот е најефикасната одбранбена мерка. Доколку жртвата користеше понова верзија на Adobe Reader, експлоатацијата не би билаа успешна. Секој систем треба да има овозможено автоматско ажурирање на сите апликации, а особено на оние кои директно обработуваат надворешни датотеки како PDF читачи, веб прелистувачи и канцелариски пакети.

2. Принцип на минимални привилегии

Малициозниот payload ги наследува привилегиите на корисникот кој ја отворил датотеката. Доколку тој корисник е стандарден корисник без администраторски права, нападачот добива ограничен пристап до системот. Затоа, корисниците никогаш не треба да работат со администраторски права во секојдневната работа.

3. Оневозможување на JavaScript во PDF читачите

Голем дел од PDF експлоатациите се потпираат на извршување на вграден JavaScript код. Оневозможувањето на JavaScript во поставките на Adobe Reader го намалува нападниот простор значително. Во Adobe Reader ова може да се направи преку Edit → Preferences → JavaScript → оневозможи „Enable Acrobat JavaScript".

4. Користење на антивирусен софтвер и EDR решенија

Иако антивирусните алатки не се сосема доверливи, како што покажа VirusTotal делот од оваа вежба, тие сепак можат да детектираат голем број познати малициозни датотеки. Современите EDR (Endpoint Detection and Response) решенија го анализираат однесувањето на процесите во реално време, а не само нивните сигнатури, со што можат да детектираат и непознати закани.

5. Мрежно филтрирање и мониторинг

Reverse shell payload-от бара излезна мрежна конекција од жртвата кон нападачот. Строгото филтрирање на излезниот сообраќај, IDS/IPS системите и мониторингот на невообичаени конекции можат да ја детектираат или блокираат оваа комуникација пред нападачот да добие целосна контрола.

6. Application Whitelisting

Алатки како AppLocker на Windows можат да спречат извршување на неовластени или непотпишани извршни датотеки. Дури и ако малициозниот payload е успешно доставен, неговото извршување би било блокирано.

7. Едукација на корисниците

Социјалниот инженеринг е главниот механизам за доставување на малициозни датотеки. Корисниците треба да бидат обучени да бидат скептични кон непознати или неочекувани датотеки, дури и кога доаѓаат од познати контакти. Никогаш не треба да се отвораат прилози од непознати извори без претходна верификација.